Stack, data models, security, compliance, testing

AcquisitionOS — AI-Powered Client Acquisition System

# Technical Architecture & Security

Complete technical overview for engineering audiences and technical due diligence.

## 1. Technology Stack

| Layer | Technology | Version | Notes |
|---|---|---|---|
| Frontend Framework | Next.js (App Router) | 16.1.3 | Turbopack, React 19 |
| UI Library | React | 19.0.0 | Server + Client components |
| Language | TypeScript | 5.x | Strict mode |
| Styling | Tailwind CSS | 4.x | shadcn/ui + Radix primitives |
| Motion | Framer Motion | 12.x | Reduced-motion support |
| Charts | Recharts | 2.15 | Area, Bar, Pie, Funnel |
| Tables | TanStack React Table | 8.21 | Virtualization ready |
| Data Fetching | TanStack React Query | 5.82 | Cache invalidation |
| ORM | Prisma | 6.x | 136 models, SQLite/Postgres |
| Database (dev) | SQLite | — | File-based, zero config |
| Database (prod) | PostgreSQL | 15+ | Connection pooling via PgBouncer |
| Cache/PubSub | Redis | 7+ | Multi-instance real-time |
| Auth | Custom JWT | — | Access(15m) + Refresh(7d) in httpOnly cookies |
| Password Hashing | bcrypt | 12 rounds | Constant-time verification |
| OAuth | Google OAuth 2.0 | — | Dynamic origin, state-encoded redirect |
| Email | Gmail SMTP + Resend | — | Nodemailer, alias-aware |
| Payments | Stripe + Razorpay | — | Auto live/test detection |
| AI Providers | OpenAI, Anthropic, Gemini, DeepSeek, OpenRouter | — | Per-user encrypted keys |
| Real-time | EventBus + SSE + Redis PubSub | — | 6 channels, last-event-id resumption |
| Deployment | Vercel | — | Serverless functions |
| Monitoring | OpenTelemetry + Sentry | — | Optional |

## 2. Data Architecture

136 Prisma models organized into domains:

| Domain | Key Models | Purpose |
|---|---|---|
| Auth & Users | User, UserSession, LoginHistory, MfaConfig, ApiKey | Authentication, sessions, RBAC |
| Organization | Organization, OrgMember, OrgInvitation | Multi-tenant org management |
| Billing | Subscription, PaymentOrder, PaymentWebhookEvent | Stripe/Razorpay billing |
| Credits | CreditsLedger, CreditAddon, DailyOutreachUsage | Credit economy |
| Leads | Lead, LeadAnalysis, LeadScore, LeadNote, LeadActivity | Lead lifecycle |
| Pipeline | PipelineStage, Deal, FollowUpReminder | Deal management |
| Outreach | OutreachMessage, OutreachSequence, SequenceStep, SequenceEnrollment | Multi-step campaigns |
| Meetings | Meeting, MeetingReminder, MeetingIntentLog | Meeting scheduling |
| Business Intelligence | BusinessProfile, WebProperty, ResearchSnapshot | AI-researched intelligence |
| Automation | AutopilotWorkflow, AutopilotRun, WorkflowDefinition, WorkflowExecution | Autopilot engine |
| Discovery | DiscoveryJob, AcquisitionCampaign | Lead discovery jobs |
| Real-time | RealtimeEvent, WsConnection, SseConnection | Event infrastructure |
| Security | AuditLog, SystemEvent, SecurityAlert, KnownDevice | Audit + security |
| Integrations | EmailAccount, EmailThread, GoogleCalendarToken | Third-party connections |

## 3. Security Architecture

### Q: Authentication security

A: JWT access tokens (15-min expiry) + refresh tokens (7-day expiry) stored in httpOnly, Secure, SameSite=Lax cookies. Password hashing: bcrypt 12 rounds. Constant-time password verification (dummy hash comparison for nonexistent users prevents timing attacks). Google OAuth with state-encoded redirect URI and CSRF protection. OTP: 6-digit, 10-min expiry, rate-limited (5/15min per IP+email), never logged.

### Q: Authorization

A: RBAC with 7 roles: super_admin, owner, admin, member, viewer, support, analytics. 50+ permissions. Server-side enforced via getSuperAdminSession (Next.js layouts) and withSuperAdmin/withPermission (API routes). Direct URL access protected server-side — client-side hiding is not the security mechanism.

### Q: Data encryption

A: OAuth tokens (Gmail, Google Calendar) encrypted at rest with AES-256-GCM. Per-user AI provider API keys stored encrypted (UserAIProvider model). Master encryption key from USER_AI_PROVIDER_ENCRYPTION_KEY env var (64-char hex). No plaintext credentials in the database.

**Q: Input validation & SSRF protection**

A: All API routes validate input via Zod or manual checks. URL-fetching endpoints (website scorer, business research) have SSRF protection — internal IPs (127.x, 10.x, 172.x, 192.168.x) are blocked. Rate limiting on all auth endpoints and credit-consuming operations.

**Q: Audit trail**

A: AuditLog model tracks every admin action with actor, action, resource, IP, user agent, timestamp. 2,232 audit entries in production. SystemEvent model tracks system-level events. SecurityAlert model for suspicious activity. Audit chain with integrity verification (hash chain, tamper-evident).

**Q: Secret management**

A: 238 environment variables identified in codebase audit. 26 currently configured in .env (gitignored). No secrets in source code (verified via grep for API key patterns — only regex detection patterns in security scanners). No NEXT_PUBLIC_ prefixed secrets (client bundle doesn't leak secrets). Debug routes expose only booleans (clientSecretSet: true/false), never actual values.

## 4. Real-Time Architecture

EventBus (singleton, in-memory) → 6 channels: lead_events, payment_events, message_events, workflow_events, ai_events, notification_events. Server-side publishers (publishLeadEvent, publishPaymentEvent, etc.) → EventBus → SSE manager broadcasts to connected clients via Server-Sent Events. Redis pubsub for multi-instance broadcast (when multiple server instances are running). SSE supports auto-reconnect with last-event-id resumption (clients don't miss events during disconnection). RealtimeEvent DB model persists events for audit/replay. useLiveUpdates() React hook subscribes to channels and triggers React Query cache invalidation.

## 5. Compliance Status

| Regulation | Status | Implementation |
|---|---|---|
| CAN-SPAM (US) | ■ Compliant | Unsubscribe links, physical address, header accuracy |
| GDPR (EU) | ■■ Schema ready | GdprRequest, DataExport models; needs legal review before EU launch |
| IT Act 2000 (India) | ■ Compliant | B2B outreach under legitimate interest; DND check planned |
| SOC 2 | ■ Not certified | Audit required for enterprise customers |
| HIPAA | ■ Not compliant | Not applicable (no health data processed) |
| PCI DSS | ■ Via Stripe | Stripe handles card data; we never touch raw card numbers |
| DPDP Act 2023 (India) | ■■ Pending review | New Indian data protection law; compliance review needed |

## 6. Testing

2,978 tests passing, 0 failing, 5 skipped. Coverage: unit tests (aggregation logic, KPI calculations, conversion math, stage mapping), integration tests (admin API authorization, CRM queries, dashboard aggregations), E2E tests (tenant isolation, idempotency/retry, error path regression, persistence/restart). Test isolation: each test file gets a unique SQLite DB copied from a schema template. Vitest 4 + @testing-library/react + Playwright.